

Risk Assessment (NIST CSF 2.0)

This assessment uses the NIST Cybersecurity Framework (CSF) 2.0, the framework that banking regulators now point institutions toward following the FFIEC's retirement of its Cybersecurity Assessment Tool (CAT) on August 31, 2025. NIST CSF 2.0 organizes a cybersecurity program into six core functions, and the institution's current and target maturity is rated against each.

2.1 The Six Core Functions

- **Govern** — establishes and monitors cybersecurity risk management strategy, expectations, and policy, including board and executive oversight
- **Identify** — understands the organization's assets, data, systems, and the cybersecurity risk to them
- **Protect** — implements safeguards to manage risk and limit or contain the impact of a cybersecurity event
- **Detect** — identifies the occurrence of a cybersecurity event in a timely manner
- **Respond** — takes action regarding a detected cybersecurity incident
- **Recover** — restores capabilities or services impaired by a cybersecurity incident

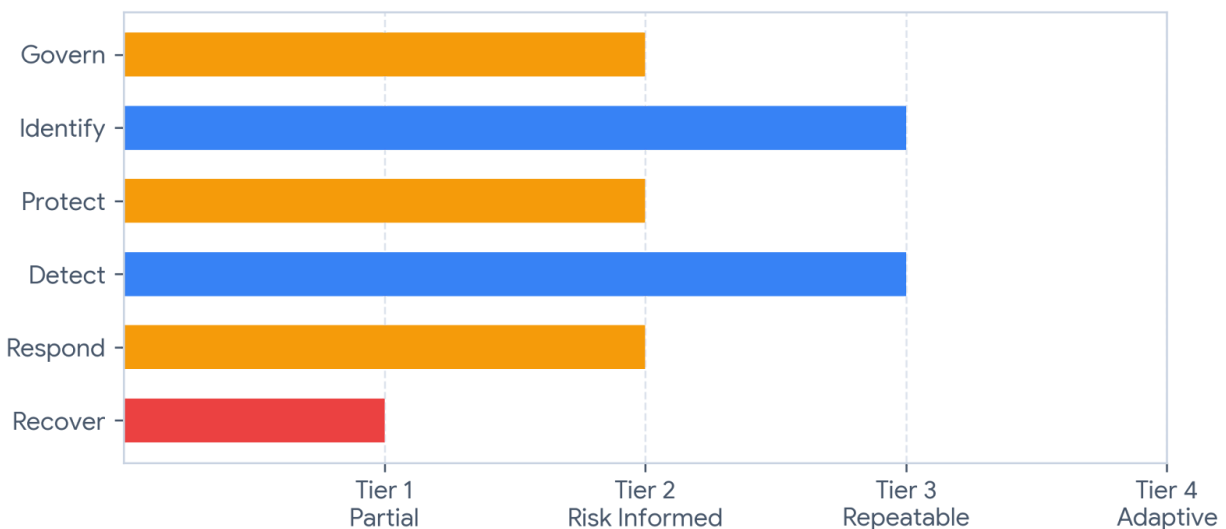
2.2 Current Maturity by Function

Maturity is rated using NIST CSF Tiers: Tier 1 (Partial), Tier 2 (Risk Informed), Tier 3 (Repeatable), Tier 4 (Adaptive).

Function	Current Tier	Notes
Govern	Tier 2 — Risk Informed	Risk committee meets quarterly and approves policy, but cyber risk appetite and supply chain risk oversight are not formally documented
Identify	Tier 3 — Repeatable	Asset inventory and annual risk assessment process are established and consistently followed

Protect	Tier 2 — Risk Informed	MFA enforced for remote access and admin accounts; encryption at rest not yet applied to all data stores
Detect	Tier 3 — Repeatable	SIEM in place with defined alerting thresholds and a documented monitoring procedure
Respond	Tier 2 — Risk Informed	Incident response plan exists and assigns roles, but has not been tested via tabletop exercise in the last 18 months
Recover	Tier 1 — Partial	Backup procedures exist, but recovery time objectives are not formally documented for all critical systems and recovery has not been tested end-to-end

NIST CSF 2.0 — Current Tier by Function



The complete 15-point risk register mapping identified enterprise threats, risk scoring, and mitigations is hosted on GitHub:

[Download the Full Risk Register Spreadsheet ([XLSX](#))]